

EDIM 보안관리계획서

EDIM Tool System — NOVA Solution · 저장소 fankh/external-projects (edim-ai-blueprint/docs)

EDIM 보안관리계획서

EDIM 구축 사업의 개발·데이터·문서·인프라 보안 기준과 운영 절차를 정의하는 착수 문서. 요구사항의 보안 항목(REQ-N-006~010·022, REQ-F-034)을 실행 계획으로 구체화하며, 보안 솔루션 연계 범위(DOC-004)가 협의 확정되면 v0.2로 갱신한다.

항목	내용
문서 버전	v0.1 (초안 — 보안 솔루션 범위 협의 전)
작성일	2026-07-11
적용 범위	개발 환경·소스코드·데이터(DB/파일)·문서 출력물·서버 인프라·운영 절차
관련 문서	사업수행계획서 · 개발표준 §8~9 · 권한승인정의서 · 위험관리대장

1. 보안 요구사항 기준선

ID	항목	기준	본 계획서
REQ-N-006	전송·저장 암호화	전 구간 TLS, 비밀번호 해시(bcrypt/argon2), 비밀키 암호화 보관	§3
REQ-N-007	접근 통제	RBAC(4단계 × 리소스 단위) + 테넌트 데이터 격리(RLS)	§2
REQ-N-008	문서 보안	Management Grade별 열람·출력 통제, 출력물 워터마크	§4
REQ-N-009	감사 로그	전 변경의 작업자·일시·전후 데이터 기록 — 보관 5년(가정)	§6
REQ-N-010	계정 정책	비밀번호 정책·실패 잠금·세션 타임아웃	§2.3
REQ-N-022	Platform 권한	AI 학습은 Platform 전용, System DB 영향 변경은 Platform 승인 필수	§2.2
REQ-F-034	문서 통제	Released Status·Version·DOC No. + 보안 솔루션 연계 (범위 협의)	§4

2. 접근 통제

2.1 역할 기반 권한 (RBAC)

- 4단계 역할: **PLATFORM > ADMIN > SETUP > GENERAL** — 메뉴 98종별 허용 매트릭스는 [권한승인정의서](#)가 단일 기준
- 서버측 강제가 원칙** — 프론트 숨김은 보안이 아님. 모든 쓰기 API는 엔드포인트별 최소 권한 검사 (PoC 검증: 쓰기=SETUP+, 사용자 잠금해제=ADMIN, GENERAL 쓰기 요청 403)
- 권한 없는 항목은 화면에 미표시(REQ-F-002) + 서버 검사 이중 적용

2.2 테넌트 격리·Platform 통제

- 멀티테넌트: 전 테이블 `tenant_id` + RLS(Row-Level Security) 적용을 기본으로 하되, 전략(컬럼/스키마/DB 분리)은 설계 단계 확정 (DB정의서 §12 미결정 #2 — [위험관리대장](#) R-10)
- AI 학습(RAW DB 구축)·System DB 영향 변경은 **Platform 제공자 전용** — 승인 이력 필수

2.3 계정·세션 정책

항목	기준 (운영 이관 시 고객 보안 정책과 합치)
비밀번호	최소 10자·복잡도 규칙, bcrypt/argon2 해시 저장 (평문·복호화 가능 저장 금지)
실패 잠금	연속 5회 실패 시 잠금 — 해제는 ADMIN (감사 기록, PoC 구현 완료)
세션	타임아웃(기본 30분)·토큰 만료 시 재로그인 강제 (PoC: HMAC Bearer, 운영: JWT+만료·회전)
계정 수명	퇴사·이동 시 즉시 비활성화, 휴면 계정 90일 잠금 (가정 — 협의)

3. 데이터 보안

- **전송**: 전 구간 TLS (개발 서버는 Let's Encrypt 적용 완료, 자동 갱신)
- **저장**: 비밀번호 해시, API 키·DB 접속 정보 등 비밀키는 환경파일 분리(`.env` , 권한 600) — 운영 이관 시 시크릿 매니저 도입 검토
- **로그**: PII·시크릿(비밀번호·토큰·API 키·개인 연락처) 로그 금지 — **개발표준 §9**. Macro 수식은 기록 가능(자산)이나 Table 데이터 값은 DEBUG 레벨만
- **백업·복구** (REQ-N-012): DB 일 1회 전체 + PITR, 파일 스토리지 버전닝 — 목표 RPO 24h / RTO 4h (가정, 협의). PoC: `edim-backup.timer` 일일 03:20 pg_dump+MinIO 백업, 보존 7일 가동 중
- **개인정보**: 수집 항목은 업무 최소한(사용자 계정·연락처)으로 한정 — 항목 확정 시 처리방침·파기 절차를 §8 협의 항목으로 확정

4. 문서 보안 (Management Grade)

- 문서 통제 메타데이터: Released Status(Set-up→Check→Approve→Accepted)·Version·DOC No.·**Management Grade(S-1~S-n)**
- Grade별 **열람·출력 통제** — 통제 대상 문서는 Print Set-up 경유 출력만 허용, 무단 다운로드 차단
- 출력물 **워터마크** (PoC 구현: 견적서 PDF CONFIDENTIAL 워터마크, Grade M 문서 워터마크)
- 외부 보안 솔루션(DRM 등) 연계는 **범위 협의 대기** (DOC-004, 보완노트 §3.3) — 연계 지점은 Print/다운로드 경로에 어댑터로 격리하여 솔루션 확정 지연이 본 개발을 차단하지 않게 한다

5. 개발 보안 (개발표준 §8 준수)

- 시크릿 저장소 커밋 금지 — pre-commit secret scan, `.env` 는 gitignore + 서버 600 권한
- 모든 외부 입력 스키마 검증(pydantic/zod), 파일 업로드는 확장자+매직바이트+크기 검증, CAD 변환은 격리 워커
- SQL 파라미터 바인딩만 허용 — Macro의 Table 참조도 식별자 화이트리스트 방식
- 동적 Form 렌더러(`tbx_ui_form`)는 스크립트 실행 금지, 선언적 바인딩만
- 의존성 lock 필수 + 주 1회 취약점 스캔(CI)

6. 감사·이력

- 자산 변경(생성·편집·삭제·승인)은 `sys_history` 에 작업자·일시·전후 데이터 기록 (REQ-F-005) — 로깅과 별개
- 구조화 JSON 로그 + `traceId` 상관관계 — 요청→서비스→워커→잡 전파
- 감사 로그 보관 **5년(가정)** — 고객 규정 확인 후 확정
- 승인·잠금해제 등 보안 이벤트는 알림(sys_notification)과 연동 (PoC 구현 완료)

7. 인프라·운영 보안

7.1 현행 개발 서버 기준선 (edim.seekerslab.com — 구축 완료)

영역	적용 상태
네트워크	ufw 허용 3포트(SSH 5022·80·443)만 개방, 내부 서비스(PG·MinIO·Jenkins·backend)는 전부 127.0.0.1 바인딩
접근	SSH 키 인증(비밀번호 로그인 차단), 문서·프로토타입 경로 Basic Auth, 앱 경로는 앱 자체 로그인
TLS	Let's Encrypt + certbot 자동 갱신
시크릿	서버 <code>.env</code> chmod 600, 저장소 커밋 금지
백업	일일 pg_dump+MinIO tar (보존 7일) + 첫 실행 검증

7.2 운영 이관 시 강화 항목 (Self-managed/SaaS 공통)

접속 IP 제한(관리 콘솔)·WAF/레이트리미트·시크릿 매니저·백업 원격지 보관·복구 리허설(분기 1회)·취약점 점검(이행 전 1회 + 연 1회)
— 고객 보안 조직과 합동 점검으로 확정

8. 사고 대응·협의 항목

사고 대응 절차: ① 탐지(모니터링·경고) → ② 격리(계정 잠금·서비스 차단) → ③ 분석(감사 로그·traceld 추적) → ④ 복구(백업 복원)
→ ⑤ 보고(고객 통지·재발 방지) — 대응 창구는 PM, 중대 사고는 운영위 즉시 보고

협의로 확정할 항목 (미확정 시 본 문서의 가정 적용):

항목	현재 가정	확정 시점
보안 솔루션(DRM) 범위 — DOC-004	자체 워터마크·Grade 통제 선행, 어댑터 연계	M1 요구 확정
감사 로그 보관 기간	5년	착수 협의
개인정보 수집 항목·파기 절차	계정·연락처 최소 수집	분석 단계
계정 정책 세부 수치(잠금·휴면·세션)	§2.3 표	착수 협의
백업 RPO/RTO·원격지 보관	24h/4h	착수 협의

변경 이력

버전	일자	내용
v0.1	2026-07-11	최초 작성 — REQ-N 보안 항목 기준선 + 개발 서버 구축 현황 반영, 보안 솔루션 범위 협의 전 초안